



# SECURITY PLAN

SEGS - Segurança de Sistemas e de Informação

**TRABALHO DESENVOLVIDO POR:**

PEDRO COELHO – 1240485

PEDRO FERREIRA – 1201172

PEDRO MOREIRA – 1211138

## Conteúdo

|                                                                       |    |
|-----------------------------------------------------------------------|----|
| Plano de Segurança e Relatório de Gestão de Riscos .....              | 4  |
| Resumo .....                                                          | 4  |
| 1. Introdução e Enquadramento Legal.....                              | 4  |
| 1.1 Âmbito e Objetivos .....                                          | 4  |
| 2. Política Geral de Segurança .....                                  | 4  |
| 2.1 Princípios de Atuação.....                                        | 5  |
| 2.2 Papéis e Responsabilidades .....                                  | 5  |
| 2.3 Recursos Humanos e Formação .....                                 | 5  |
| 3. Inventário de Ativos .....                                         | 6  |
| 3.1 Dependências de Ativos e Pontos Únicos de Falha .....             | 7  |
| 4. Gestão de Risco (Metodologia: ISO/IEC 27005) .....                 | 7  |
| 4.1 Riscos Identificados .....                                        | 7  |
| 4.2 Matriz de Risco (Simplificada).....                               | 8  |
| 4.3 Plano de Tratamento de Risco.....                                 | 8  |
| 5. Gestão de Incidentes .....                                         | 9  |
| 5.1 Incident Response Roles and Communication .....                   | 9  |
| 5.2 Incident Scenarios and Playbooks .....                            | 9  |
| 5.3 SLAs e Timelines .....                                            | 10 |
| 6. Controlos Técnicos e Físicos .....                                 | 10 |
| 6.1 Segmentação de Rede e Firewalling (VLANs) .....                   | 10 |
| 6.2 Segurança Física e Controlos Ambientais.....                      | 10 |
| 6.3 Mapeamento Controlo-Risco .....                                   | 11 |
| 7. Monitorização, Registo e Auditoria .....                           | 12 |
| 8. Conformidade, Revisão e Validade do Plano .....                    | 12 |
| 9. Referências .....                                                  | 12 |
| Exercise 1 - PL 10 – DNS (Configuração com 3 VMs) .....               | 13 |
| Topologia das Máquinas Virtuais .....                                 | 13 |
| 1. Definir Zonas DNS e Instalar Unbound (VM1).....                    | 13 |
| 3. Políticas de Resolução Interna/Externa (VM1, VM2, VM3).....        | 15 |
| 4. Configurar DNS-over-TLS (VM1) .....                                | 16 |
| 5. O que é DNSSEC? .....                                              | 17 |
| 6. Racional para bloquear resolução externa por ativos internos ..... | 18 |
| 7. Permitir apenas resolução de google.com (VM1) .....                | 18 |
| 8. Logging e Auditoria DNS + DLP/Exfiltração (VM1) .....              | 19 |
| Exercise 1 - PL 11 – Firewall .....                                   | 20 |

|                                                                                                                                                                                                                                                                                                                                                             |    |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----|
| 1. Investigate and describe what is IP Tables [3]; .....                                                                                                                                                                                                                                                                                                    | 20 |
| 2. From your previous laboratory, try to implement IPtables on the Linux machine such that you can access TCP/22 (SSH) from your machine but deny access from the Windows Server. (If you delete those machines you can always spin up a new Linux machine); Allow all egress flows such that all domain services still work; Did RPC calls break? [4]..... | 21 |
| 3. Persist the changes and try to reboot the server; .....                                                                                                                                                                                                                                                                                                  | 22 |
| 4. Take the opportunity to learn about the Windows Firewall with Advanced Security [5] .....                                                                                                                                                                                                                                                                | 24 |
| 5. Create a Rule to accept TCP/3389 (RDP) from the Linux Server; test it by trying to connect directly from your machine. ....                                                                                                                                                                                                                              | 24 |
| 6. Investigate the possibility of creating an IPSec Tunnel; In what cases do you seem fit to implement such a rule [6] .....                                                                                                                                                                                                                                | 25 |
| Referências .....                                                                                                                                                                                                                                                                                                                                           | 25 |

|                                                                                           |    |
|-------------------------------------------------------------------------------------------|----|
| Figura 1 Instalação do Unbound na VM1 .....                                               | 13 |
| Figura 2 Ativação do serviço Unbound .....                                                | 13 |
| Figura 3 Definição da configuração base do unbound .....                                  | 14 |
| Figura 4 Verificação de estado de atividade do unbound .....                              | 14 |
| Figura 5 Teste dig a partir da VM2 para o server Unbound .....                            | 14 |
| Figura 6 Teste dig a partir da VM3 para o server Unbound .....                            | 14 |
| Figura 7 Definição de subzonas internas na configuração do Unbound .....                  | 14 |
| Figura 8 Reinício dos serviços Unbound .....                                              | 14 |
| Figura 9 Testes dig para as subzonas definidas .....                                      | 15 |
| Figura 10 Mapeamento de acesso interno/externo através de views .....                     | 15 |
| Figura 11 Definição da configuração da vista interna .....                                | 15 |
| Figura 12 Definição da configuração da vista externa .....                                | 15 |
| Figura 13 Testes dig de acesso à vista interna .....                                      | 16 |
| Figura 14 Testes dig de acesso à vista externa .....                                      | 16 |
| Figura 15 Configuração de certificados para configuração do TLS .....                     | 16 |
| Figura 16 Configuração de encaminhamento de DNS para o Google .....                       | 16 |
| Figura 17 Teste dig para reencaminhamento de DNS .....                                    | 17 |
| Figura 18 Configuração de bloqueio de todas os domínios que não google.com .....          | 18 |
| Figura 19 Ativação da whitelist no Unbound .....                                          | 19 |
| Figura 20 Teste de domínios com o comando dig .....                                       | 19 |
| Figura 21 Criação de um ficheiro customizado de logs .....                                | 19 |
| Figura 22 Configuração de logging .....                                                   | 19 |
| Figura 23 Análise do resultado da configuração de logs .....                              | 20 |
| Figura 24 - Comando para permitir Pings .....                                             | 21 |
| Figura 25 - Teste de pings entre host e vms .....                                         | 21 |
| Figura 26 - Verificação das regras .....                                                  | 21 |
| Figura 27 - Políticas de Padrão .....                                                     | 22 |
| Figura 28 - Tabela das políticas definidas .....                                          | 22 |
| Figura 29 - Instalação do pacote para persistir as regras .....                           | 22 |
| Figura 30 - Persistências das Regras definidas .....                                      | 22 |
| Figura 31 - Verificação, após reboot da persistência das regras .....                     | 23 |
| Figura 32 - Inicialização do ssh .....                                                    | 23 |
| Figura 33 - Ssh sucedido do host para VM Linux .....                                      | 23 |
| Figura 34 - Ssh falhado da VM Windows para VM Linux .....                                 | 23 |
| Figura 35 - Verificação das conexões da VM Linux .....                                    | 24 |
| Figura 36 - Configurar a nova Regra de Firewall para permitir os acesos da VM Linux ..... | 24 |
| Figura 37 - Conexão bem-sucedida da VM Linux .....                                        | 24 |
| Figura 38 - Confirmação que a regra rejeita o Host .....                                  | 25 |

# Plano de Segurança e Relatório de Gestão de Riscos

Conformidade: Decreto-Lei n.º 65/2021 e Política de Defesa Cibernética da EU

Membros do grupo:

- 1240485 – Pedro Coelho
- 1201172 – Pedro Ferreira
- 1211138 – Pedro Moreira

Todos os membros do grupo contribuíram equitativamente para todas as secções do planeamento, execução técnica e elaboração deste relatório.

## Resumo

Este Plano de Segurança apresenta uma abordagem abrangente para proteger a organização descrita no cenário SEGS (Sede e Edifício Anexo). Está alinhado com a Política de Defesa Cibernética da UE e com o Decreto-Lei n.º 65/2021. O plano inclui: Política Geral de Segurança, Inventário de Ativos com classificação CIA, Gestão de Riscos de acordo com a ISO/IEC 27005, procedimentos de Gestão de Incidentes (com definição de papéis e SLAs), Controlo Técnico e Físico, e os exercícios laboratoriais de DNS como Apêndice A. O objetivo é garantir a confidencialidade, integridade e disponibilidade dos sistemas críticos, assegurando simultaneamente a auditabilidade e a possibilidade de revisão.

## 1. Introdução e Enquadramento Legal

Este Plano de Segurança aplica-se a todos os sistemas de informação, equipamentos de rede e espaços físicos da Sede (HQ) e do Edifício Anexo. Segue as diretivas da UE transpostas para o direito português (Lei n.º 46/2018) e regulamentadas pelo Decreto-Lei n.º 65/2021. O artigo 7.º do Decreto-Lei n.º 65/2021 exige um Plano de Segurança atualizado, aprovado pelo CISO e mantido com evidência de revisões periódicas.

### 1.1 Âmbito e Objetivos

**Âmbito:** Abrange servidores, routers, switches e estações de trabalho dos utilizadores presentes na topologia de rede fornecida.

**Objetivos:** (1) Proteger a Confidencialidade, Integridade e Disponibilidade (CIA) dos dados; (2) Assegurar a conformidade legal; (3) Definir papéis, responsabilidades e procedimentos de tratamento de incidentes; (4) Implementar controlos técnicos e físicos proporcionais para mitigar os riscos identificados.

## 2. Política Geral de Segurança

**Declaração de Política:** A informação é um ativo estratégico. A organização compromete-se a proteger os ativos de informação contra ameaças acidentais ou deliberadas através da aplicação de controlos técnicos, organizacionais e humanos.

## 2.1 Princípios de Atuação

- **Least Privilege:** conceder aos utilizadores apenas as permissões mínimas necessárias.
- **Defence in Depth:** controlos em camadas ao nível físico, de rede, de host e de aplicação.
- **Segregation of Duties:** separação entre funções de desenvolvimento, administrativas e operacionais.
- **Accountability & Auditing:** todas as ações privilegiadas devem ser registadas e revistas.
- **Compliance:** alinhamento com o Decreto-Lei n.º 65/2021, RGPD e normas relevantes.

## 2.2 Papéis e Responsabilidades

**Chief Information Security Officer (CISO):** aprova o Plano de Segurança, lidera a resposta a incidentes e é o principal ponto de contacto com o CNCS e a CNPD.

**Administradores de Sistemas:** mantêm os servidores, aplicam atualizações, gerem backups e controlos de acesso.

**Utilizadores:** cumprem as políticas de segurança, reportam incidentes e participam na formação obrigatória.

## 2.3 Recursos Humanos e Formação

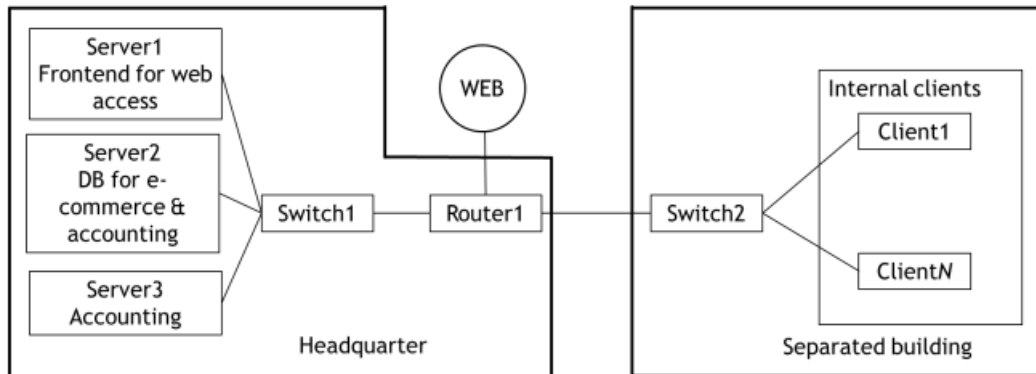
Todos os colaboradores são sujeitos a uma verificação de segurança ('screening') adequada ao risco da sua função antes da admissão.

Durante a integração ('onboarding'), são atribuídos os acessos físicos e lógicos estritamente necessários, os quais são revistos periodicamente e revogados imediatamente aquando da cessação de funções ('offboarding').

A formação em segurança é obrigatória na admissão, sendo complementada por ações anuais de reciclagem e simulações de phishing. O sucesso destas formações é avaliado através de testes, e é mantido um registo formal de todas as sessões e participantes para efeitos de auditoria.

As violações das políticas de segurança desencadeiam um processo disciplinar definido.

### 3. Inventário de Ativos



O inventário de ativos identifica ativos de hardware, software e dados, com classificações de impacto segundo a Tríade CIA (Confidencialidade – Integridade – Disponibilidade) (1 baixo – 5 alto). As dependências são registradas.

| ID   | Ativo                   | Tipo                 | Localização | Descrição                                                                  | Conf (1-5) | Integ (1-5) | Dispon (1-5) |
|------|-------------------------|----------------------|-------------|----------------------------------------------------------------------------|------------|-------------|--------------|
| A-01 | Server 1 (Frontend Web) | Hardware/Application | HQ          | Servidor web público                                                       | 4          | 3           | 3            |
| A-02 | Server 2 (Database)     | Hardware/Data        | HQ          | Base de dados e-commerce e contabilidade com dados pessoais e financeiros. | 5          | 5           | 5            |
| A-03 | Server 3 (Accounting)   | Hardware/Applicação  | HQ          | Serviços internos de contabilidade.                                        | 4          | 4           | 4            |
| A-04 | Router 1                | Network              | HQ          | Gateway central entre HQ e WEB Externa; SPOF                               | 3          | 3           | 5            |
| A-05 | Switch 1                | Network              | HQ          | Switch de agregação dos servidores da                                      | 3          | 3           | 4            |

|      |             |              |                   |                                              |   |   |   |
|------|-------------|--------------|-------------------|----------------------------------------------|---|---|---|
|      |             |              |                   | HQ.                                          |   |   |   |
| A-06 | Switch 2    | Network      | Separate Building | Agrega clientes internos.                    | 2 | 2 | 3 |
| A-07 | Clients 1-N | Workstations | Separate Building | Endpoints de utilizadores; risco de phishing | 2 | 3 | 2 |

### 3.1 Dependências de Ativos e Pontos Únicos de Falha

O Router 1 é um ponto único de falha (SPOF) para a conectividade entre edifícios e tráfego de saída. O Servidor 2 depende do Servidor 1 para o tratamento seguro de entradas web. São obrigatórios backups off-site para garantir a resiliência da base de dados.

## 4. Gestão de Risco (Metodologia: ISO/IEC 27005)

Processo: Definição do contexto → Identificação do risco → Análise do risco (probabilidade/impacto) → Avaliação do risco → Tratamento → Monitorização. Os riscos utilizam uma escala de 1-5 para probabilidade e impacto; Nível de Risco = Probabilidade × Impacto.

### 4.1 Riscos Identificados

| ID Risco | Descrição                                                  | Ativos afetados                            | Probabilidade (1-5) | Impacto (1-5) |
|----------|------------------------------------------------------------|--------------------------------------------|---------------------|---------------|
| R1       | Injeção SQL conduzindo à extração não autorizada de dados. | Ativos: Server 2 (DB); Server 1 (Frontend) | 4                   | 5             |
| R2       | Falha de Hardware ou Disrupção Física no Router de Borda   | Ativos: Router 1 and HQ Server Room        | 2                   | 5             |

Justificação:

R1 – Injeção SQL conduzindo à extração não autorizada de dados

A probabilidade é elevada (4) devido à exposição do frontend web à Internet e à interação direta com a base de dados, tornando a aplicação um alvo frequente de ataques por injeção SQL caso existam falhas de validação ou configuração. O impacto é muito alto (5), uma vez que a exploração bem-sucedida pode resultar na divulgação, alteração ou perda de dados críticos de e-commerce e contabilidade, com consequências legais, financeiras e reputacionais significativas.

## R2 – Disrupção física causando indisponibilidade

A probabilidade é baixa a moderada (2), dado que eventos físicos graves (falhas elétricas prolongadas, incêndios, danos no router) são menos frequentes e podem ser mitigados com controlos físicos adequados. No entanto, o impacto é muito alto (5), pois a indisponibilidade do Router 1 ou da sala de servidores da sede pode interromper completamente o acesso à rede, aos serviços internos e externos, afetando de forma crítica a continuidade do negócio.

## 4.2 Matriz de Risco (Simplificada)

Pontuação de risco = Probabilidade × Impacto.

Classificação: 1-6 Baixo, 7-14 Médio, 15-20 Alto, 21-25 Crítico.

R1: 20 -> Alto

R2: 10 -> Médio

Em resultado da avaliação, o risco R1 é classificado como “Alto”, devido à elevada probabilidade de exploração de vulnerabilidades na aplicação web e ao impacto crítico associado à exposição de dados sensíveis.

O risco R2 é classificado como “Médio”, uma vez que, apesar do impacto ser elevado, a probabilidade de ocorrência é relativamente baixa devido às medidas preventivas existentes.

## 4.3 Plano de Tratamento de Risco

| ID Risco | Estratégia         | Controlos Primários                                                                                                                                                                                                   | Risco Residual |
|----------|--------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------|
| R1       | Mitigar            | Validação de inputs, queries parametrizadas, WAF, DMZ, ACLs rigorosas, revisões de código, testes de segurança, registo de auditoria.                                                                                 | Médio          |
| R2       | Mitigar/Transferir | Instalar UPS e alimentação elétrica redundante, sistemas de deteção e supressão de incêndios, backups off-site, seguro para hardware crítico e manutenção de equipamento de reserva (cold/hot spare) para o Router 1. | Baixo          |

A estratégia definida para o R1 foca-se na mitigação através de controlos técnicos e processuais que reduzem significativamente a probabilidade de exploração de injeção SQL; contudo, devido à exposição contínua do sistema web e à dependência de código aplicacional, permanece um risco residual médio.

No R2, a combinação de medidas de mitigação e transferência (seguro) reduz de forma substancial a probabilidade e o impacto de disrupções físicas, resultando num risco residual baixo, uma vez que eventos extremos continuam possíveis, mas com efeitos controlados.

## 5. Gestão de Incidentes

Esta secção define procedimentos de deteção, escalamento, contenção e recuperação. Todos os incidentes devem ser registados. As notificações ao CNCS e à CNPD seguem os prazos legais.

Para efeitos deste plano, define-se 'Incidente de Segurança' como qualquer evento que comprometa a confidencialidade, integridade ou disponibilidade dos ativos de informação, ou que constitua uma violação das políticas de segurança estabelecidas, exigindo uma resposta imediata para minimizar o impacto no negócio.

### 5.1 Incident Response Roles and Communication

**Testemunha do Incidente:** qualquer colaborador.

**Responsável pelo Incidente:** administrador designado pelo CISO.

**Gestor do Incidente:** CISO (Chief Information Security Officer).

**Fluxo:** Reporte interno → Gestor do Incidente → CISO → Notificações externas

### 5.2 Incident Scenarios and Playbooks

Cenário A — Violação de Dados (R1):

- **Trigger:** Evidência de acesso não autorizado ou exfiltração a partir do Servidor 2 (alertas do IDS, consultas anómalas à base de dados, registos de exfiltração de dados).
- Playbook steps:
  1. **Deteção:** Validar os alertas, recolher e preservar os logs (sistema, web, base de dados, firewall).
  2. **Erradicação:** Aplicar patches/correções de vulnerabilidades, proceder à rotação de credenciais e remover artefactos maliciosos.
  3. **Recuperação:** Restaurar os serviços a partir de backups conhecidos como válidos, após validação.
  4. **Reporte:** Preparar relatório interno; notificar a CNPD no prazo de 72 horas caso tenham sido comprometidos dados pessoais; notificar o CNCS conforme aplicável.

Cenário B — Falha Crítica de Conectividade (R2):

- **Trigger:** Falha do Router 1 detetada através de monitorização ou perda de conectividade.
- Playbook steps:
  1. **Avaliação:** Determinar a causa (energia, falha de hardware).
  2. **Mitigação/Continuidade:** Ativar o router de reserva (cold spare) que se encontra pré-configurado e armazenado fisicamente no armário de segurança da sala de servidores (on-site). Comutar os cabos para o equipamento de reserva e validar a conectividade.
  3. **Recuperação:** Reprovisionar o hardware, restaurar a configuração a partir de backups encriptados e testar a conectividade de ponta a ponta.
  4. **Revisão pós-incidente:** Atualizar os runbooks e corrigir as fragilidades identificadas.

### 5.3 SLAs e Timelines

| Gravidade do Incidente                                      | Tempo de resposta                                      | Objetivo de Recuperação (RTO) |
|-------------------------------------------------------------|--------------------------------------------------------|-------------------------------|
| Crítico (violação de dados, indisponibilidade generalizada) | 15 minutos (confirmação pelo Responsável do Incidente) | 4 horas                       |
| Alto (servidor único indisponível)                          | 30 minutos                                             | 24 horas                      |
| Médio/Baixo (problemas de utilizadores)                     | 4 horas                                                | 72 horas                      |

## 6 Controlos Técnicos e Físicos

Os controlos estão mapeados aos riscos identificados. Cada controlo inclui a respetiva responsabilidade e passos de verificação.

### 6.1 Segmentação de Rede e Firewalling (VLANs)

Arquitetura: VLAN10 (DMZ) → Servidor 1; VLAN20 (Core) → Servidores 2 e 3; VLAN30 (Utilizadores) → Clientes. O Router 1 aplica ACLs que negam tráfego da VLAN30 para a VLAN20, exceto para portas específicas de gestão ou de aplicação. Um WAF é implementado à frente do Servidor 1 para inspecionar o tráfego HTTP(S) e bloquear ataques comuns de injeção.

### 6.2 Segurança Física e Controlos Ambientais

Esta secção detalha as medidas implementadas para proteger a integridade física dos ativos localizados na Sede ("Headquarter") e no Edifício Anexo ("Separated Building").

- **Controlo de Acessos Físicos:**
  - **Sala de Servidores (Sede):** O acesso é restrito exclusivamente ao CISO e Administradores de Sistemas, sendo controlado através de autenticação

biométrica (impressão digital) com registo de logs de entrada/saída. A porta possui fecho automático e resistência ao fogo.

- **Equipamentos de Rede (Edifício Separado):** O Switch 2 e o bastidor de distribuição estão trancados num armário técnico ("rack") com chave, prevenindo a manipulação não autorizada de cabos ou portas por parte dos utilizadores locais (Client1-N).

- **Controlos Ambientais (Deteção e Supressão):**

- Implementação de sensores de monitorização de temperatura e humidade ligados a um sistema de alerta centralizado.
- Sistema de deteção de incêndios e supressão automática (baseada em gás limpo/agentes inertes) para evitar danos nos equipamentos eletrónicos causados por água.

- **Resiliência Elétrica (Power):**

- Instalação de UPS (Uninterruptible Power Supply) online de dupla conversão para suportar o **Router 1** (SPOF) e os **Servidores 1, 2 e 3**. Isto garante o encerramento seguro ("graceful shutdown") em caso de falha elétrica prolongada e protege contra picos de tensão.
- Manutenção de um router de reserva ("cold spare") armazenado em local seguro na Sede para substituição imediata em caso de avaria de hardware (R2).

- **Segurança Física dos Suportes de Backup:**

- Os suportes físicos de armazenamento (discos externos ou cassetes, se aplicável) que aguardam rotação para *off-site* são guardados num cofre à prova de fogo e de água localizado numa zona distinta da sala de servidores, garantindo a salvaguarda dos dados mesmo em caso de sinistro na sala principal.

## 6.3 Recuperação de Dados e Backup

Para garantir a disponibilidade e integridade dos dados (mitigação de R1 e R2), implementa-se uma política de backups rigorosa seguindo a regra 3-2-1: três cópias dos dados, em dois suportes diferentes (disco local e storage), com uma cópia off-site (cloud imutável) para proteção contra ransomware e desastres físicos. A periodicidade é diária (incremental) e semanal (full), permitindo cumprir o RPO definido.

## 6.4 Mapeamento Controlo-Risco

| Controlo                    | Mitiga    | Responsável / Verificação                                   |
|-----------------------------|-----------|-------------------------------------------------------------|
| WAF + validação de inputs   | R1 (SQLi) | Equipa de Aplicações /<br>Revisão semanal das regras do WAF |
| Segmentação por VLAN + ACLs | R1        | Equipa de Redes /<br>Verificação trimestral                 |

|                                                |    |                               |
|------------------------------------------------|----|-------------------------------|
| UPS, supressão de incêndios, router de reserva | R2 | Infraestruturas / Teste anual |
|------------------------------------------------|----|-------------------------------|

## 7. Monitorização, Registo e Auditoria

O registo centralizado (SIEM) recolhe logs de firewall, IDS, aplicações e bases de dados. São definidos períodos de retenção de logs e revisões periódicas. O registo de DNS inclui logs de consultas e respostas para suporte a DLP e deteção de exfiltração. São obrigatórios scans regulares de vulnerabilidades e testes de intrusão anuais.

## 8. Conformidade, Revisão e Validade do Plano

Este plano é válido por um período de um ano após a aprovação. Deve ser revisto após qualquer incidente grave, após alterações significativas à infraestrutura ou mediante orientações do CNCS. As atividades de conformidade (auditorias internas) decorrem semestralmente.

## 9. Referências

- Decreto-Lei n.º 65/2021 (Portugal) – Segurança das Redes e Sistemas de Informação
- Lei n.º 46/2018 – Transposição da Diretiva NIS da EU
- ISO/IEC 27005:2018 – Gestão de riscos de segurança da informação
- ISO/IEC 27001:2022 – Sistemas de gestão da segurança da informação
- NIST SP 800-61r2 – Guia de Tratamento de Incidentes de Segurança Informática
- CNCS – Orientações do Centro Nacional de Cibersegurança

## Exercise 1 - PL 10 – DNS (Configuração com 3 VMs)

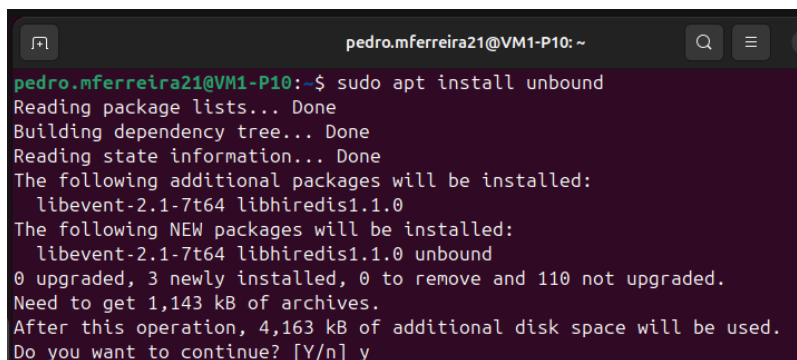
### Topologia das Máquinas Virtuais

Para a realização do presente exercício, definiu-se a utilização de 3 máquinas virtuais, com funções distintas:

- VM1 – Servidor DNS (Unbound) – IP: 10.0.0.1
  - Responsável por:
    - Instalação e configuração do Unbound
    - Criação das zonas internas e externas
    - Criação das sub-zonas
    - Aplicação das políticas de resolução (interno/externo)
    - Encaminhamento DNS-over-TLS
    - RPZ para permitir apenas google.com
    - Logging e auditoria DNS
- VM2 – Cliente Interno – IP: 10.0.0.10
  - Responsável por:
    - Realizar apenas resoluções internas
    - Testar segmentação e políticas
- VM3 – Cliente Externo – IP: 10.0.0.20
  - Responsável por:
    - Realizar apenas resoluções da zona externa
    - Validar bloqueios de acesso à zona interna

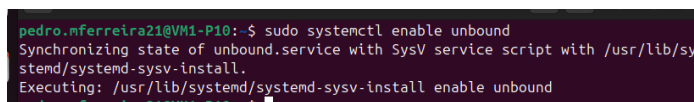
### 1. Definir Zonas DNS e Instalar Unbound (VM1)

Na primeira alínea, o foco é ativação inicial do unbound, e a configuração base. Procede-se então a instalação e ativação do serviço unbound.



```
pedro.mferreira21@VM1-P10: ~  
pedro.mferreira21@VM1-P10:~$ sudo apt install unbound  
Reading package lists... Done  
Building dependency tree... Done  
Reading state information... Done  
The following additional packages will be installed:  
  libevent-2.1-7t64 libhiredis1.1.0  
The following NEW packages will be installed:  
  libevent-2.1-7t64 libhiredis1.1.0 unbound  
0 upgraded, 3 newly installed, 0 to remove and 110 not upgraded.  
Need to get 1,143 kB of archives.  
After this operation, 4,163 kB of additional disk space will be used.  
Do you want to continue? [Y/n] y
```

Figura 1 Instalação do Unbound na VM1



```
pedro.mferreira21@VM1-P10:~$ sudo systemctl enable unbound  
Synchronizing state of unbound.service with SysV service script with /usr/lib/sy  
stemd/systemd-sysv-install.  
Executing: /usr/lib/systemd/systemd-sysv-install enable unbound
```

Figura 2 Ativação do serviço Unbound

Com o serviço ativo, cria-se um ficheiro de configuração personalizada /etc/unbound/unbound.conf.d/zones.conf, e define-se uma configuração base que suporte uma zona interna e externa, como demonstrado abaixo.

```

GNU nano 7.2 /etc/unbound/unbound.conf.d/zones.conf *
server:
  interface: 10.0.0.1
  access-control: 10.0.0.0/24 allow
  # ZONA INTERNA
  local-zone: "segsi.local" static
  local-data: "vm1.segsi.local. IN A 10.0.0.1"
  local-data: "vm2.segsi.local. IN A 10.0.0.10"

  # ZONA EXTERNA
  local-zone: "segsi.external" static
  local-data: "vm3.segsi.external. IN A 10.0.0.20"

```

Figura 3 Definição da configuração base do unbound

Através de `sudo systemctl status unbound` verifica-se que o server unbound está ativo.

```

[sudo] password for pedro.mferreira21:
Warning: The unit file, source configuration file or drop-ins of unbound.service
● unbound.service - Unbound DNS server
   Loaded: loaded (/usr/lib/systemd/system/unbound.service; enabled; preset:
   Active: active (running) since Thu 2025-12-04 19:44:19 UTC; 2h 1min ago
     Docs: man:unbound(8)
    Main PID: 1213 (unbound)
      Tasks: 1 (limit: 2265)
     Memory: 14.6M (peak: 14.9M)
        CPU: 625ms
    CGroup: /system.slice/unbound.service
            └─1213 /usr/sbin/unbound -d -p

```

Figura 4 Verificação de estado de atividade do unbound

Neste momento, é esperado que ambas a VM2 e a VM3 sejam capazes de aceder ao server DNS disponibilizado na VM1, e confirmamos este facto com recurso ao comando `dig`.

```

pedromferreira21@VM2-PL10:~$ dig @10.0.0.1 vm2.segsi.local +short
10.0.0.10

```

Figura 5 Teste dig a partir da VM2 para o server Unbound

```

pedromferreira21@VM3-PL10:~$ dig @10.0.0.1 vm3.segsi.external +short
10.0.0.20

```

Figura 6 Teste dig a partir da VM3 para o server Unbound

## 2. Criar Sub-Zonas 'eng' e 'testing' (VM1)

Para criar várias subzonas, é necessário recorrer à alteração do ficheiro `zones.conf` definido na alínea anterior.

```

GNU nano 7.2 /etc/unbound/unbound.conf.d/zones.conf
server:
  interface: 10.0.0.1
  access-control: 10.0.0.0/24 allow

  #####
  # ZONA INTERNA
  #####
  local-zone: "segsi.local" static
  local-data: "vm1.segsi.local. IN A 10.0.0.1"
  local-data: "vm2.segsi.local. IN A 10.0.0.10"

  # SUBZONAS INTERNAS
  local-zone: "eng.segsi.local" static
  local-data: "srv1.eng.segsi.local. IN A 10.0.0.101"
  local-data: "srv2.eng.segsi.local. IN A 10.0.0.102"

  local-zone: "testing.segsi.local" static
  local-data: "dev1.testing.segsi.local. IN A 10.0.0.201"
  local-data: "dev2.testing.segsi.local. IN A 10.0.0.202"

  #####
  # ZONA EXTERNA
  #####
  local-zone: "segsi.external" static
  local-data: "vm3.segsi.external. IN A 10.0.0.20"

```

Figura 7 Definição de subzonas internas na configuração do Unbound

Após isso, é necessário reiniciar os serviços do `unbound` para garantir a atualização das configurações.

```

pedro.mferreira21@VM1-P10:~$ sudo systemctl restart unbound
pedro.mferreira21@VM1-P10:~$ systemctl daemon-reload

```

Figura 8 Reinício dos serviços Unbound

E verifica-se novamente se as configuração são válidas, testando no cliente interno (VM2) as subzonas que foram adicionadas.

```
pedromferreira21@VM2-PL10:~$ dig @10.0.0.1 srv1.eng.segsi.local +short
10.0.0.101
pedromferreira21@VM2-PL10:~$ dig @10.0.0.1 dev1.testing.segsi.local +short
rt
10.0.0.201
```

Figura 9 Testes dig para as subzonas definidas

### 3. Políticas de Resolução Interna/Externa (VM1, VM2, VM3)

Para resolver a **Alínea 3** ("Criar políticas para que apenas um IP possa resolver a rede interna e outro IP possa resolver a parte externa"), é necessário utilizar uma funcionalidade do Unbound chamada **Views** (Vistas).

As *Views* permitem que o servidor DNS dê respostas diferentes dependendo de **quem** está a fazer a pergunta (neste caso, baseado no endereço IP de origem). Assim, configura-se:

```
GNU nano 7.2 /etc/unbound/unbound.conf.d/zones.conf
server:
  interface: 10.0.0.1

  # 1. Definir o controlo de acesso básico
  access-control: 10.0.0.0/24 allow

  # 2. Mapear IPs específicos para Vistas específicas
  # A VM2 (10.0.0.10) vai para a vista interna
  access-control-view: 10.0.0.10/32 vista-interna

  # A VM3 (10.0.0.20) vai para a vista externa
  access-control-view: 10.0.0.20/32 vista-externa
```

Figura 10 Mapeamento de acesso interno/externo através de views

Note-se que todos os IPs da rede com a máscara /24 conseguem aceder ao server definido, mas realiza-se um mapeamento para as *Views* para configurar de forma independente a zona (e subzonas) interna, e a zona externa.

```
#####
# VISTA INTERNA (Apenas para VM2)
#####
view:
  name: "vista-interna"

  # Zona Interna Principal
  local-zone: "segsi.local" static
  local-data: "vm1.segsi.local. IN A 10.0.0.1"
  local-data: "vm2.segsi.local. IN A 10.0.0.10"

  # Subzonas Internas
  local-zone: "eng.segsi.local" static
  local-data: "srv1.eng.segsi.local. IN A 10.0.0.101"
  local-data: "srv2.eng.segsi.local. IN A 10.0.0.102"

  local-zone: "testing.segsi.local" static
  local-data: "dev1.testing.segsi.local. IN A 10.0.0.201"
  local-data: "dev2.testing.segsi.local. IN A 10.0.0.202"
```

Figura 11 Definição da configuração da vista interna

```
#####
# VISTA EXTERNA (Apenas para VM3)
#####
view:
  name: "vista-externa"

  # Zona Externa
  local-zone: "segsi.external" static
  local-data: "vm3.segsi.external. IN A 10.0.0.20"
```

Figura 12 Definição da configuração da vista externa

Pressupõe-se então que com estas alterações, a VM2 tenho apenas acesso a zonas internas, e o acesso seja recusado para a zona externa, o que é demonstrado na figura seguinte.

```
pedronferreira21@VM2-PL10:~$ dig @10.0.0.1 vm1.segsi.local +short
10.0.0.1
pedronferreira21@VM2-PL10:~$ dig @10.0.0.1 vm3.segsi.external +short
pedronferreira21@VM2-PL10:~$ dig @10.0.0.1 vm3.segsi.external

; <<>> DiG 9.18.39-0ubuntu0.24.04.2-Ubuntu <<>> @10.0.0.1 vm3.segsi.external
; (1 server found)
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NXDOMAIN, id: 55186
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 0, AUTHORITY: 1, ADDITIONAL: 1
```

Figura 13 Testes dig de acesso à vista interna

Por outro lado, realizam-me os mesmo testes na VM3, mas com o objetivo de demonstrar que esta apenas tem acesso à zona externa:

```
pedronferreira21@VM3-PL10:~$ dig @10.0.0.1 vm3.segsi.external +short
10.0.0.20
pedronferreira21@VM3-PL10:~$ dig @10.0.0.1 vm1.segsi.local

; <<>> DiG 9.18.39-0ubuntu0.24.04.2-Ubuntu <<>> @10.0.0.1 vm1.segsi.local
; (1 server found)
;; global options: +cmd
;; Got answer:
;; WARNING: .local is reserved for Multicast DNS
;; You are currently testing what happens when an mDNS query is leaked to DNS
;; ->>HEADER<<- opcode: QUERY, status: NXDOMAIN, id: 55814
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 0, AUTHORITY: 1, ADDITIONAL: 1
```

Figura 14 Testes dig de acesso à vista externa

#### 4. Configurar DNS-over-TLS (VM1)

No ficheiro *zones.conf* realiza-se duas configurações principais para atingir o pretendido, primeiramente o bloco *tls-cert-bundle* para que o unbound tenha conhecimento de onde deve procurar quais são as autoridades confiáveis (como o caso do Google); e o bloco de *forward-zone*:

- **name: "."**: Significa "para qualquer outro domínio que não esteja nas zonas locais (como google.pt, facebook.com, etc.)".
- **forward-tls-upstream: yes**: Força a encriptação.
- **8.8.8.8@853#dns.google**: O formato é IP@PORTA#HOSTNAME. A porta **853** é a porta padrão para DNS seguro (DoT), ao contrário da 53 (UDP normal).

```
server:
  interface: 10.0.0.1

# --- Configuração de Segurança (TLS) ---
# Caminho para os certificados de raiz do Ubuntu para validar o Google
tls-cert-bundle: /etc/ssl/certs/ca-certificates.crt
```

Figura 15 Configuração de certificados para configuração do TLS

```
forward-zone:
  name: "."
  forward-tls-upstream: yes

# Google DNS Primário (IPv4)
forward-addr: 8.8.8.8@853#dns.google

# Google DNS Secundário (IPv4)
forward-addr: 8.8.4.4@853#dns.google
```

Figura 16 Configuração de encaminhamento de DNS para o Google

Testando a partir do ambiente da VM2, verifica-se o sucesso da configuração testando o encaminhamento do pedido para o Google, como demonstrado na imagem seguinte.

```

pedromferreira21@VM2-PL10:~$ dig @10.0.0.1 google.com

; <<>> DiG 9.18.39-0ubuntu0.24.04.2-Ubuntu <<>> @10.0.0.1 google.com
; (1 server found)
;; global options: +cmd
;; Got answer:
;; ->HEADER<<- opcode: QUERY, status: NOERROR, id: 63848
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
;; QUESTION SECTION:
;google.com.                IN      A
;; ANSWER SECTION:
google.com.                 34      IN      A      216.58.215.142
;; Query time: 265 msec
;; SERVER: 10.0.0.1#53(10.0.0.1) (UDP)
;; WHEN: Sat Dec 06 16:58:17 UTC 2025
;; MSG SIZE rcvd: 55

```

Figura 17 Teste dig para reencaminhamento de DNS

Ao usar DNS over TLS (DoT), benefício de três pilares fundamentais da segurança da informação que o DNS tradicional (UDP porta 53) não tem:

#### 1. Confidencialidade (Privacidade):

- **Sem DoT:** Os pedidos DNS viajam em texto simples. Qualquer pessoa na rede (o administrador do laboratório, o ISP, ou um hacker) consegue ver exatamente que sites estou aceder.
- **Com DoT:** O pedido é encriptado. Quem interceptar o tráfego apenas visualiza "lixo" ilegível a ir para o IP da Google, ou seja, não sabem *que que pedido foi feito*.

#### 2. Integridade:

- **Sem DoT:** É possível fazer ataques de *Man-in-the-Middle*. Qualquer sujeito pode interceptar o pedido para um determinado *domain* e responder com o IP de um site falso para retirar as credenciais utilizadas.
- **Com DoT:** Como o canal é encriptado e assinado, se alguém tentar alterar a resposta no caminho, o protocolo deteta e rejeita a conexão.

#### 3. Autenticação:

- Ao utilizar o `#dns.google` na configuração, o *Unbound* verifica o certificado digital do servidor. Isto garante que o sistema está realmente a falar com a Google e não com um servidor malicioso que poderá tentar simular ser a Google.

## 5. O que é DNSSEC?

**DNSSEC** (Domain Name System Security Extensions) é um conjunto de extensões ao protocolo DNS original que adiciona uma camada de segurança criptográfica às resoluções de nomes. O protocolo DNS original não foi desenhado com segurança em mente, o que o torna vulnerável a ataques de interceção e manipulação [1].

O principal objetivo do DNSSEC é garantir a **integridade** e a **autenticidade** dos dados. Ao contrário do DNS sobre TLS (DoT), que encripta o canal para privacidade, o DNSSEC não esconde os dados; em vez disso, assina digitalmente os registos de recursos (RRsets) utilizando criptografia de chave pública.

O funcionamento do DNSSEC baseia-se em dois pilares fundamentais:

1. **Autenticação da Origem dos Dados (Data Origin Authentication):** Garante ao resolver (neste caso, o Unbound) que os dados recebidos tiveram origem no servidor autoritativo legítimo daquela zona e não num atacante a tentar fazer-se passar por ele.

2. **Integridade dos Dados (Data Integrity):** Garante que os dados não foram alterados em trânsito. Se um atacante interceptar o pacote e mudar o IP de destino (ataque *Man-in-the-Middle* ou *Cache Poisoning*), a assinatura digital deixará de corresponder aos dados, e o resolver rejeitará a resposta como inválida (retornando o erro SERVFAIL).

Para tal, o DNSSEC estabelece uma "Cadeia de Confiança" (*Chain of Trust*) desde a zona raiz (Root Zone .) até ao domínio final, permitindo que cada nível da hierarquia valide a chave pública do nível abaixo através de registos DS (*Delegation Signer*).

Em resumo, enquanto o DoT protege a privacidade da comunicação ("quem está a falar com quem"), o DNSSEC protege a veracidade da informação ("o que foi dito é verdade").

## 6. Racional para bloquear resolução externa por ativos internos

Bloquear ativos internos de resolver a zona DNS externa é uma prática fundamental na implementação de *Split-Horizon DNS*. Esta segregação garante que a infraestrutura interna comunica com os recursos utilizando os seus endereços IP privados e não os seus endereços públicos.

Esta política justifica-se por dois motivos técnicos principais:

1. **Eficiência de Encaminhamento e Prevenção de NAT Loopback:** Se um cliente interno resolver o IP público de um serviço (zona externa), o tráfego terá de ir até à firewall/router de fronteira e voltar para dentro. Muitos routers não suportam este comportamento (*NAT Hairpinning*) por defeito, o que resultaria em falha de conexão. O uso da zona interna garante o acesso direto e eficiente via IP privado [2].
2. **Princípio do Menor Privilégio (*Least Privilege*):** Ao limitar a visibilidade, reduz-se a superfície de ataque. Máquinas internas não devem ter conhecimento da topologia pública da rede, prevenindo o mapeamento desnecessário da infraestrutura externa a partir de dentro e forçando o tráfego a fluir apenas pelos canais internos autorizados e monitorizados.

## 7. Permitir apenas resolução de google.com (VM1)

Para configurar o Unbound de forma a permitir **apenas** o domínio google.com e bloquear todo o resto da internet, vamos utilizar a funcionalidade *RPZ (Response Policy Zones)*.

Esta configuração cria o que chamamos de *Walled Garden*, e para o efeito necessitamos de criar o ficheiro de regras (Zona RPZ), e posteriormente alterar a configuração do *Unbound* para ter este ficheiro em consideração.

Primeiramente, configuramos em `/etc/unbound/` o ficheiro `whitelist.zone`, que define as regras mencionadas.



```
pedro.mferreira21@VM1-P10: /etc/unbound
GNU nano 7.2                                whitelist.zone *
$TTL 300
@ SOA localhost. root.localhost. 1 3600 600 86400 300
@ NS localhost.

; REGRA 1: Permitir google.com e todos os seus subdomínios
; "rpz-passthru" significa "deixar passar sem alterar"
google.com      CNAME    rpz-passthru.

; REGRA 2: Bloquear TUDO o resto (Wildcard)
; O ponto final (.) devolve NXDOMAIN (Não existe)
* CNAME         .
```

Figura 18 Configuração de bloqueio de todas os domínios que não google.com

Com o anterior definido, recorreremos às configurações do Unbound para ativar o módulo de resposta, com base na *whitelist*.

```
pedro.mferreira21@VM1-P10: /etc/unbound/unbound.conf.d
GNU nano 7.2 zones.conf *

# --- ATIVAR MÓDULO RPZ ---
# Define a ordem de processamento.
# respip: módulo que aplica as políticas RPZ
# validator: valida DNSSEC
# iterator: resolve o nome
module-config: "respip validator iterator"

rpz:
  name: "whitelist"
  zonefile: "/etc/unbound/whitelist.zone"
  rpz-log: yes
  rpz-log-name: "RPZ-LOG"
```

Figura 19 Ativação da whitelist no Unbound

Testando a configuração realizada, como esperado, verifica-se que apenas o domínio google.com é permitido, e outros domínios *e.g.* sapo.pt recebem *NXDOMAIN*, ou seja, é como se o domínio não existisse.

```
pedromferreira21@VM2-PL10: ~
pedromferreira21@VM2-PL10: ~$ dig @10.0.0.1 google.com +short
172.217.17.14
pedromferreira21@VM2-PL10: ~$ dig @10.0.0.1 sapo.pt +short
pedromferreira21@VM2-PL10: ~$ dig @10.0.0.1 sapo.pt

;<>> DIG 9.18.39-0ubuntu0.24.04.2-Ubuntu <>> @10.0.0.1 sapo.pt
; (1 server found)
; global options: +cmd
; Got answer:
; ->>HEADER<- opcode: QUERY, status: NXDOMAIN, id: 28349
; flags: qr aa rd ra; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
;; QUESTION SECTION:
;sapo.pt.                                IN      A

;; Query time: 3 msec
;; SERVER: 10.0.0.1#53(10.0.0.1) (UDP)
;; WHEN: Sat Dec 06 17:46:29 UTC 2025
;; MSG SIZE rcvd: 36
```

Figura 20 Teste de domínios com o comando dig

## 8. Logging e Auditoria DNS + DLP/Exfiltração (VM1)

Para auditoria, precisamos de ativar o registo de *queries* (o que perguntam) e *replies* (o que o servidor responde).

Primeiramente, definimos o ficheiro de Log, e para o efeito criamos um diretório próprio, uma vez que o *Unbound* é executado com um utilizador restrito, ou seja, se tentarmos gravar os logs em */var/log/*, vamos obter erros.

```
pedro.mferreira21@VM1-P10: /etc/unbound/unbound.conf.d
pedro.mferreira21@VM1-P10: /etc/unbound/unbound.conf.d$ sudo mkdir -p /var/log/unbound
pedro.mferreira21@VM1-P10: /etc/unbound/unbound.conf.d$ sudo touch /var/log/unbound/unbound.log
pedro.mferreira21@VM1-P10: /etc/unbound/unbound.conf.d$ sudo chown -R unbound:unbound /var/log/unbound
pedro.mferreira21@VM1-P10: /etc/unbound/unbound.conf.d$
```

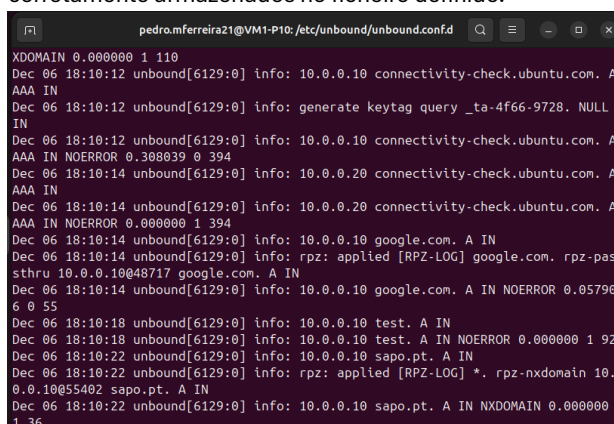
Figura 21 Criação de um ficheiro customizado de logs

Na configuração de *server* do unbound, remetemos os logs para o ficheiro anteriormente criado através da seguinte configuração:

```
# --- CONFIGURAÇÃO DE AUDITORIA (LOGGING) ---
verbosity: 1 # Nível 1 é suficiente para ver o tráfego
log-queries: yes # Regista o que foi perguntado
log-replies: yes # Regista o que foi respondido
log-time-ascii: yes # Datas legíveis para humanos
logfile: "/var/log/unbound/unbound.log"
```

Figura 22 Configuração de logging

Assim, replicando os testes da alínea anterior, podemos verificar com o nível de verbosidade definido, os logs corretamente armazenados no ficheiro definido.



```
pedro.mferreira21@VM1-P10: /etc/unbound/unbound.conf.d
XDOMAIN 0.000000 1 110
Dec 06 18:10:12 unbound[6129:0] info: 10.0.0.10 connectivity-check.ubuntu.com. A
AAA IN
Dec 06 18:10:12 unbound[6129:0] info: generate keytag query _ta-4f66-9728. NULL
IN
Dec 06 18:10:12 unbound[6129:0] info: 10.0.0.10 connectivity-check.ubuntu.com. A
AAA IN NOERROR 0.308039 0 394
Dec 06 18:10:14 unbound[6129:0] info: 10.0.0.20 connectivity-check.ubuntu.com. A
AAA IN
Dec 06 18:10:14 unbound[6129:0] info: 10.0.0.20 connectivity-check.ubuntu.com. A
AAA IN NOERROR 0.000000 1 394
Dec 06 18:10:14 unbound[6129:0] info: 10.0.0.10 google.com. A IN
Dec 06 18:10:14 unbound[6129:0] info: rpz: applied [RPZ-LOG] google.com. rpz-pas
sthru 10.0.0.10@48717 google.com. A IN
Dec 06 18:10:14 unbound[6129:0] info: 10.0.0.10 google.com. A IN NOERROR 0.05790
6 0 55
Dec 06 18:10:18 unbound[6129:0] info: 10.0.0.10 test. A IN
Dec 06 18:10:18 unbound[6129:0] info: 10.0.0.10 test. A IN NOERROR 0.000000 1 92
Dec 06 18:10:22 unbound[6129:0] info: 10.0.0.10 sapo.pt. A IN
Dec 06 18:10:22 unbound[6129:0] info: rpz: applied [RPZ-LOG] *. rpz-nxdomain 10.
0.0.10@55402 sapo.pt. A IN
Dec 06 18:10:22 unbound[6129:0] info: 10.0.0.10 sapo.pt. A IN NXDOMAIN 0.000000
1 36
```

Figura 23 Análise do resultado da configuração de logs

A auditoria no Unbound transforma o DNS de um "tubo opaco" num canal monitorizável.

**1. Data Exfiltration by DNS (O Ataque)** A exfiltração de dados via DNS (ou *DNS Tunneling*) é uma técnica usada por atacantes para roubar dados de uma rede protegida, contornando firewalls tradicionais. Como a maioria das firewalls bloqueia portas "estranhas" mas permite a porta 53 (DNS) para a Internet, os atacantes codificam dados sensíveis dentro dos próprios pedidos DNS.

- **Exemplo Prático:** Imagina que um atacante quer roubar uma password ("segredo123") da tua rede. O malware na máquina infetada faz um pedido DNS por: segredo123.atacante.com
- O teu servidor Unbound, inocentemente, encaminha este pedido para o servidor DNS do atacante (porque ele é autoritativo para atacante.com).
- O atacante recebe o pedido no seu servidor e regista: "Recebi 'segredo123'". O dado foi roubado sem nunca passar uma conexão HTTP ou FTP.

**2. Data Leakage Prevention (DLP) (A Defesa)** O papel do **DLP** neste contexto é detetar e bloquear estas tentativas. No entanto, é impossível detetar o que não se vê. É aqui que entra a configuração de **Auditing** que acabaste de fazer:

- **Visibilidade:** Sem log-queries: yes, o administrador de sistemas é "cego". O tráfego sai e ninguém sabe o conteúdo.
- **Análise Comportamental:** Com os logs ativos, ferramentas de SIEM (Security Information and Event Management) podem analisar os ficheiros de texto à procura de padrões suspeitos, tais como:
  - Pedidos com subdomínios excessivamente longos e aleatórios (ex: a8f93...4b2.badsite.com).
  - Um volume anormal de pedidos DNS para um único domínio desconhecido num curto espaço de tempo.

## Exercise 1 - PL 11 – Firewall

### 1. Investigate and describe what is IP Tables [3];

O **IPtables** é uma ferramenta de *user-space* em sistemas operativos Linux que permite configurar as regras de filtro de pacotes do *kernel* (o módulo **Netfilter**). Ele atua como uma **firewall stateless** (sem estado) ou **stateful** (com estado).

A arquitetura do Netfilter, gerida pelo IPtables, baseia-se em **tabelas** que contêm **cadeias** (ou *chains*), onde cada cadeia é composta por uma lista de **regras**.

- **Tabelas Principais:** filter (para filtrar pacotes), nat (para *Network Address Translation*) e mangle (para alterar cabeçalhos de pacotes).
- **Cadeias Principais (na tabela filter):**
  - **INPUT:** Para pacotes destinados à máquina local.
  - **OUTPUT:** Para pacotes gerados pela máquina local.
  - **FORWARD:** Para pacotes que passam pela máquina (se estiver a funcionar como *router*).

2. From your previous laboratory, try to implement IPtables on the Linux machine such that you can access TCP/22 (SSH) from your machine but deny access from the Windows Server. (If you delete those machines you can always spin up a new Linux machine); Allow all egress flows such that all domain services still work; Did RPC calls break? [4]

Para realizar este trabalho foi necessário criar duas VMs novas visto que acabei por perder as criadas anteriormente por um erro dentro da virtual box.

Para a criação dessas duas vms recorri a uma VM Linux Ubuntu LTS 24 e um Windows Server 2022 em modo de Server Core, sem interface gráfica que era o suficiente para o pretendido neste projeto.

Os endereços de cada uma das 3 máquinas são os seguintes

**Host : 192.168.56.01**

**VM Linux (Ubuntu) : 192.168.1.102**

**VM Windows : 192.168.1.101**

Dentro do powershell Windows, tanto para a VM como para o Host, executei este comando de forma a poder realizar pings e testar a conexão entre todos os ambientes.

```
PS C:\WINDOWS\system32> New-NetFirewallRule -DisplayName "Allow Ping Host" -Direction Inbound -Protocol ICMPv4 -icmpType 8 -Action Allow
```

Figura 24 - Comando para permitir Pings

```
PS C:\WINDOWS\system32> ping 192.168.56.101
Pinging 192.168.56.101 with 32 bytes of data:
Reply from 192.168.56.101: bytes=32 time<1ms TTL=128
Reply from 192.168.56.101: bytes=32 time<1ms TTL=128

Ping statistics for 192.168.56.101:
    Packets: Sent = 2, Received = 2, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 0ms, Average = 0ms
Control-C
PS C:\WINDOWS\system32> ping 192.168.56.102
Pinging 192.168.56.102 with 32 bytes of data:
Reply from 192.168.56.102: bytes=32 time<1ms TTL=64
Reply from 192.168.56.102: bytes=32 time<1ms TTL=64

Ping statistics for 192.168.56.102:
    Packets: Sent = 2, Received = 2, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 0ms, Average = 0ms
Control-C
```

Figura 25 - Teste de pings entre host e vms

Dentro da VM Linux, executei o comando abaixo para verificar se havia alguma regra por default.

```
 vboxuser@VMUbuntuPL11:~$ sudo iptables -L -v -n
Chain INPUT (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source         destination

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source         destination

Chain OUTPUT (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source         destination
```

Figura 26 - Verificação das regras

Após isso, **defini Políticas Padrão**:

- # 1. Permite o que já está ligado (para o teu SSH não cair)
- # 2. Permite o sistema falar consigo mesmo (Loopback) - Vital para o sudo não encravar
- # 3. Permite acesso SSH vindo do teu PC (Host)
- # 4. Bloqueia o SSH da VM Windows
- # 5. Definir a política padrão para BLOQUEAR por default tanto pacotes com destino (Input) como pacotes que passem pela VM (Forward), mas permitindo pacotes saírem da VM

```
 vboxuser@UbuntuF11:~$ sudo iptables -n conntrack --cstate ESTABLISHED,RELATED -j ACCEPT
(sudo) password for vboxuser:
vboxuser@UbuntuF11:~$ sudo iptables -n INPUT -i lo -j ACCEPT
vboxuser@UbuntuF11:~$ sudo iptables -n INPUT -p tcp --dport 22 -s 192.168.56.1 -j ACCEPT
vboxuser@UbuntuF11:~$ sudo iptables -n INPUT -s 192.168.56.101 -j DROP
vboxuser@UbuntuF11:~$ sudo iptables -F INPUT DROP
vboxuser@UbuntuF11:~$ sudo iptables -F OUTPUT ACCEPT
vboxuser@UbuntuF11:~$ sudo iptables -F FORWARD DROP
```

Figura 27 - Políticas de Padrão

Ficando com a seguinte tabela

```
vboxuser@UbuntuF11:~$ sudo iptables -L -v -n
Chain INPUT (policy DROP 0 packets, 0 bytes)
  pkts bytes target     prot opt in     out     source               destination
  4800 ACCEPT 0      --    --    --    0.0.0.0/0            0.0.0.0/0
  20 2000 ACCEPT 0      --    --    --    0.0.0.0/0            0.0.0.0/0
  0 0 ACCEPT 0      --    --    --    192.168.56.1         0.0.0.0/0        tcp dpt:22
  0 0 DROP 0      --    --    --    192.168.56.101       0.0.0.0/0

Chain FORWARD (policy DROP 0 packets, 0 bytes)
  pkts bytes target     prot opt in     out     source               destination
Chain OUTPUT (policy ACCEPT 30 packets, 2500 bytes)
  pkts bytes target     prot opt in     out     source               destination
```

Figura 28 - Tabela das políticas definidas

**Pergunta sobre RPC:**

Ao configurar a política padrão da cadeia de saída como 'ACEITAR' (iptables -P OUTPUT ACCEPT), garantimos que a máquina pode iniciar qualquer comunicação para o exterior. Adicionalmente, a regra que aceita estados ESTABLISHED e RELATED na cadeia de entrada (INPUT) assegura que as respostas a esses pedidos retornam corretamente. Desta forma, as chamadas RPC (Remote Procedure Calls) e outros serviços de domínio continuam a funcionar sem interrupções

**3. Persist the changes and try to reboot the server;**

Objetivo: Garantir que as regras não desaparecem após o reboot.

**Instalar o serviço de persistência:**

Para instalar o serviço de persistências realizei o seguinte:

```
vboxuser@UbuntuF11:~$ sudo apt install iptables-persistent
```

Figura 29 - Instalação do pacote para persistir as regras

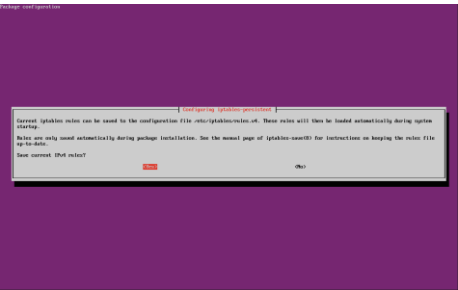


Figura 30 - Persistências das Regras definidas

Corri o comando `sudo netfilter-persistent save` para garantir que realmente gravou as regras definidas, e reiniciei o sistema com `sudo reboot`.

Para verificar que as regras foram guardadas realizei o seguinte que já tinha verificado antes, e manteve-se a configuração definida.

```

vboxuser@VMUbuntuP111:~$ sudo iptables -L -v -n
(ando) password for vboxuser:
Chain INPUT (policy DROP 0 packets, 0 bytes)
  pkts bytes target     prot opt in     out     source            destination        ctstate RELATED,ESTABLISHED
   40 1167s ACCEPT     0    --  *      *        0.0.0.0/0         0.0.0.0/0
   10 71s ACCEPT     0    --  lo     *        0.0.0.0/0         0.0.0.0/0
    0 0 ACCEPT     6    --  *      *      192.168.56.1      0.0.0.0/0          tcp dpt:22
    0 0 DROP      0    --  *      *      192.168.56.101    0.0.0.0/0
Chain FORWARD (policy DROP 0 packets, 0 bytes)
  pkts bytes target     prot opt in     out     source            destination
Chain OUTPUT (policy ACCEPT 49 packets, 4822 bytes)
  pkts bytes target     prot opt in     out     source            destination
vboxuser@VMUbuntuP111:~$

```

Figura 31 - Verificação, após reboot da persistência das regras

Para testar se as regras foram bem aplicadas, realizei os seguintes testes.

Como indicado na pergunta, permiti o SSH 22 do meu host (.1) e rejeitei o SSH da máquina virtual Windows (.101) que por default já não funcionaria devido à configuração da figura 27.

Para testar liguei o acesso ssh na VM Linux através dos comandos

```
sudo apt update
```

```
sudo apt install openssh-server -y
```

E depois da instalação

```

vboxuser@VMUbuntuP111:~$ sudo systemctl start ssh
vboxuser@VMUbuntuP111:~$ sudo systemctl enable ssh
Synchronizing state of ssh.service with SysV service script with /usr/lib/systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable ssh
Created symlink /etc/systemd/system/ssh.service → /usr/lib/systemd/system/ssh.service.
Created symlink /etc/systemd/system/multi-user.target.wants/ssh.service → /usr/lib/systemd/system/ssh.service.
vboxuser@VMUbuntuP111:~$

```

Figura 32 - Inicialização do ssh

Como esperado o Host conseguiu conectar, no entanto a VM Windows server não, como esperado.

```

PS C:\VM\Ubuntu\system32 ssh vboxuser@192.168.56.102
vboxuser@192.168.56.102's password:
Welcome to Ubuntu 24.04.3 LTS (GNU/Linux 6.8.0-90-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Mon Dec 22 03:32:30 PM UTC 2025

System load:          0.01
Usage of /:           12.7% of 24.44GB
Memory usage:         7%
Swap usage:           0%
Processes:            146
Users logged in:      1
IPv4 address for enp0s3: 10.0.2.15
IPv6 address for enp0s3: fd17:625c:f037:2:a00:27ff:fe51:4280

Expanded Security Maintenance for Applications is not enabled.

9 updates can be applied immediately.
To see these additional updates run: apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

vboxuser@VMUbuntuP111:~$

```

Figura 33 - Ssh sucedido do host para VM Linux

```

Administrator: C:\Windows\system32\cmd.exe
PS C:\Users\Administrator> ssh vboxuser@192.168.56.102
ssh: connect to host 192.168.56.102 port 22: Connection timed out
PS C:\Users\Administrator> Test-NetConnection 192.168.56.102 -Port 22
WARNING: TCP connect to (192.168.56.102 : 22) failed
WARNING: Ping to 192.168.56.102 failed with status: 'timedOut'

ComputerName           : 192.168.56.102
RemoteAddress          : 192.168.56.102
RemotePort             : 22
InterfaceAlias         : Ethernet 2
SourceAddress          : 192.168.56.101
PingSucceeded          : False
PingReplyDetails (RTT) : 0 ms
TcpTestSucceeded       : False

PS C:\Users\Administrator>

```

Figura 34 - Ssh falhado da VM Windows para VM Linux

Apesar das regras, podemos verificar através de um ping a google.com ou até à VM Windows que a VM Linux não ficou isolada.

```

vboxuser@VMUbuntuPL11:~$ ping -c 4 google.com
PING google.com (142.250.184.14) 56(84) bytes of data:
64 bytes from mad41s10-in-f14.1e100.net (142.250.184.14): icmp_seq=1 ttl=255 time=28.7 ms
64 bytes from mad41s10-in-f14.1e100.net (142.250.184.14): icmp_seq=2 ttl=255 time=24.6 ms
64 bytes from mad41s10-in-f14.1e100.net (142.250.184.14): icmp_seq=3 ttl=255 time=26.7 ms
^C
--- google.com ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2002ms
rtt min/avg/max/ndev = 24.550/26.656/28.708/1.697 ms
vboxuser@VMUbuntuPL11:~$ ping 192.168.56.101
PING 192.168.56.101 (192.168.56.101) 56(84) bytes of data:
64 bytes from 192.168.56.101: icmp_seq=1 ttl=128 time=1.20 ms
64 bytes from 192.168.56.101: icmp_seq=2 ttl=128 time=1.45 ms
^C
--- 192.168.56.101 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1002ms
rtt min/avg/max/ndev = 1.203/1.326/1.449/0.123 ms

```

Figura 35 - Verificação das conexões da VM Linux

#### 4. Take the opportunity to learn about the Windows Firewall with Advanced Security [5]

A **Firewall do Windows com Segurança Avançada (WFAS)** é uma firewall *host-based* (baseada no anfitrião) e com estado (stateful) que se integra no Windows. Em comparação com soluções de firewall tradicionais, a WFAS tem a capacidade de atuar em três níveis:

1. **Filtro de Pacotes (Packet Filtering):** Controla o tráfego de entrada e saída com base em endereços IP, portas, protocolos, entre outros.
2. **Segurança de Ligação IPsec (IPsec Connection Security):** Permite criar regras de segurança de ligação (Connection Security Rules) que podem exigir autenticação ou encriptação via **IPsec** (Internet Protocol Security) para comunicações específicas entre máquinas.
3. **Filtragem de Aplicações:** Permite ou bloqueia o tráfego com base na aplicação que o está a gerar, adicionando uma camada de controlo mais fina.

#### 5. Create a Rule to accept TCP/3389 (RDP) from the Linux Server; test it by trying to connect directly from your machine.

A regra foi criada com o comando `New-NetFirewallRule ... -RemoteAddress 192.168.56.102` (o IP correto do Linux), sendo que primeiro ativou-se o RDP, depois permitiu-se RDP nas definições avançadas do sistema, para o caso de estar bloqueado e personalizou-se a regra para a VM Linux.

```

PS C:\Users\Administrator> Set-ItemProperty -Path 'HKLM\System\CurrentControlSet\Control\Terminal Server' -name 'fDenyTSConnections' -value 0
PS C:\Users\Administrator> Enable-NetFirewallRule -DisplayGroup "Remote Desktop"
PS C:\Users\Administrator> New-NetFirewallRule -DisplayName "PL11_AllowRDPtoLinux" -Direction Inbound -LocalPort 3389 -Protocol TCP -Action Allow -RemoteAddress 192.168.56.102

Name                : {42fbdce1-2de8-4fac-a4bb-460800139385}
DisplayName          : PL11_AllowRDPtoLinux
Description          :
DisplayGroup         :
Group                :
Enabled              : True
Profile              : Any
Platform             : {}
Direction            : Inbound
Action               : Allow
EdgeTraversalPolicy  : Block
SourceSourceMapping  : False
LocalOnlyMapping     : False
Owner                :
PriorityStatus        : OK
Status               : The rule was parsed successfully from the store. (65536)
EnforcementStatus    : NotApplicable
PolicyStoreSource     : PersistentStore
PolicyStoreSourceType : Local
RemoteDynamicKeywordAddresses : {}

```

Figura 36 - Configurar a nova Regra de Firewall para permitir os acessos da VM Linux

Dentro da VM Linux testei a configuração seguindo os seguintes passos para testar a conexão, que como se pode ver a figura foi bem-sucedida.

```

vboxuser@VMUbuntuPL11:~$ nc -zv 192.168.56.101 3389
Connection to 192.168.56.101 3389 port [tcp/ms-wbt-server] succeeded!

```

Figura 37 - Conexão bem-sucedida da VM Linux

No Host, ao testar a conexão com a VM Windows onde configurei agora a regra para apenas aceitar a VM Linux, obtive a falha esperada.

```
PS C:\WINDOWS\system32> test-NetConnection 192.168.56.101 -Port 3389
WARNING: TCP connect to (192.168.56.101 : 3389) failed

ComputerName      : 192.168.56.101
RemoteAddress     : 192.168.56.101
RemotePort        : 3389
InterfaceAlias    : Ethernet 2
SourceAddress     : 192.168.56.1
PingSucceeded     : True
PingReplyDetails (RTT) : 0 ms
TcpTestSucceeded  : False
```

Figura 38 - Confirmação que a regra rejeita o Host

## 6. Investigate the possibility of creating an IPSec Tunnel; In what cases do you seem fit to implement such a rule [6]

A Firewall do Windows com Segurança Avançada (WFAS) permite a criação de um **Tunnel IPSec** (Internet Protocol Security) através das **Regras de Segurança de Ligação** (Connection Security Rules).

Um tunnel IPSec usa os protocolos **AH** (Authentication Header) ou **ESP** (Encapsulating Security Payload) para fornecer:

- **Autenticação:** Assegura que o tráfego vem de uma fonte confiável.
- **Integridade:** Garante que os dados não foram alterados em trânsito.
- **Confidencialidade/Encriptação (apenas com ESP):** Torna os dados ilegíveis a terceiros.

### Casos em que é útil implementar tal regra:

É adequado implementar um Tunnel IPSec sempre que seja necessário proteger a comunicação através de uma rede potencialmente não confiável (como a Internet ou uma rede de laboratório partilhada). Exemplos:

- **Comunicação de Servidores Críticos:** Proteger a comunicação entre um Servidor de Aplicações e a base de dados.
- **Comunicação entre Domain Controllers (DC-to-DC):** Essencial para a replicação segura de informações de domínio numa rede.
- **VPNs:** A base para muitas implementações de Virtual Private Network.
- **Comunicações de Gestão Remota Seguras:** Garantir que o tráfego RDP, SSH ou WinRM é autenticado e encriptado.

## Referências

- [1] R. Arends, R. Austein, M. Larson, D. Massey, and S. Rose, "DNS Security Introduction and Requirements," IETF, RFC 4033, Mar. 2005. [Online]. Available: <https://datatracker.ietf.org/doc/html/rfc4033>.
- [2] S. Cheshire and M. Krochmal, "Architectural Considerations on Application Features in the DNS," IETF, RFC 6950, Oct. 2013, sec. 4. [Online]. Available: <https://datatracker.ietf.org/doc/html/rfc6950#section-4>
- [3] "iptables - archwiki." [Online]. Available: <https://wiki.archlinux.org/title/iptables>
- [4] M. Anicas, "Iptables essentials: Common firewall rules and commands," Jul 2021. [Online]. Available: <https://www.digitalocean.com/community/tutorials/iptables-essentials-common-firewall-rules-and-commands>
- [5] Paolomatarazzo, "Windows firewall overview - windows security." [Online]. Available: <https://learn.microsoft.com/en-us/windows/security/operating-system-security/network-security/windows-firewall/>
- [6] "Securing dc to dc communication with ipsec using windows firewall with advanced security (wfas) connection security rules," Feb 2020. [Online]. Available: <https://techcommunity.microsoft.com/t5/core-infrastructure-and-security/securing-dc-to-dc-communication-with-ipsec-using-windows/ba-p/257700>